Awal Global Consults Limited

RISK ASSESSMENT

Information Security Risk Assessment and Register

Fifteen risks to Example Foods Ltd identified, scored on a 5×5 likelihood and impact matrix, evaluated against the board's risk appetite and treated with ISO/IEC 27001:2022 Annex A controls.

Client	**Example Foods Ltd (a fictional company, used for illustration only)**
Method	**ISO 31000 process, 5×5 qualitative matrix**
Control set	**ISO/IEC 27001:2022 Annex A**
Assessor	**A.O. Abdullateef, Awal Global Consults Limited (RC-9282103)**
Version	**1.0, 3 November 2026**

Illustrative sample. Example Foods Ltd is a fictional company. This document shows the method, structure and quality of a real engagement; it is not a client deliverable and contains no client information. Prepared by A.O. Abdullateef, Awal Global Consults Limited (RC-9282103).

1. Summary

Before treatment, 3 risks are Critical and 2 are High. The Critical risks, supplier payment fraud, WhatsApp account takeover and business email compromise, are the ways Nigerian small businesses most often lose money, and all three can be cut sharply within a month at little cost: a call-back rule, two-step verification and staff training. After the planned treatment no risk remains above the appetite set by the board.

Rating	Inherent	Residual (planned)
Low	1	10
Medium	9	5
High	2	0
Critical	3	0

> **Risk appetite.** Example Foods Ltd accepts Low risks, tolerates Medium risks with a dated treatment plan, and does not accept High or Critical risks to customer money, customer personal data or regulatory standing.

2. Method

1. **Context:** scope and obligations taken from the gap assessment.
2. **Identify:** for each important asset, the threats that could affect it and the weaknesses that make them possible.
3. **Analyse:** likelihood (1–5) × impact (1–5) = inherent score, considering controls already in place.
4. **Evaluate:** compare each score with the risk appetite and the rating bands below.
5. **Treat:** choose controls (mapped to ISO/IEC 27001:2022 Annex A), name an owner and a date, and estimate residual risk.
6. **Monitor:** owners report monthly on High and Critical risks; the full register is reviewed every quarter and after any incident or major change.

Likelihood

#	Rating	Guide
1	Rare	Not expected in the next 3 years
2	Unlikely	Could happen once in 3 years
3	Possible	Could happen once a year
4	Likely	Expected several times a year
5	Almost certain	Expected monthly or is already happening

Impact

#	Rating	Guide
1	Negligible	Loss under N100,000; no customer impact
2	Minor	Loss up to N1m; brief disruption; no personal data exposed
3	Moderate	Loss up to N10m; a day's disruption; limited personal data exposed
4	Major	Loss up to N50m; several days' disruption; reportable personal data breach
5	Severe	Loss over N50m; regulatory sanction; lasting reputational harm

Rating bands

Score	Rating	Required response
1–4	Low	Accept and monitor
5–9	Medium	Treat within 6 months
10–14	High	Treat within 3 months; owner reports monthly
15–25	Critical	Treat immediately; escalate to the board

3. Heat maps

Inherent risk

	1 Negligible	2 Minor	3 Moderate	4 Major	5 Severe
5 Almost certain	5	10	15	20	25
4 Likely	4	8	12	16 RO1 RO3	20 RO2
3 Possible	3	6	9 RO6 RO8 RO9 R12	12 RO4 RO5	15
2 Unlikely	2	4 R13	6 R11 R15	8 RO7 R10 R14	10
1 Rare	1	2	3	4	5

Rows: likelihood. Columns: impact. Each cell shows the score (likelihood × impact) and the risks in it.

Residual risk after planned treatment

	1 Negligible	2 Minor	3 Moderate	4 Major	5 Severe
5 Almost certain	5	10	15	20	25
4 Likely	4	8	12	16	20
3 Possible	3	6	9	12	15
2 Unlikely	2	4 RO6 RO9	6 RO3 RO4 R10	8 RO1	10
1 Rare	1	2 R11 R13 R15	3 RO7 RO8 R12 R14	4 RO5	5 RO2

Rows: likelihood. Columns: impact. Each cell shows the score (likelihood × impact) and the risks in it.

4. Risk register

Sorted by inherent score. L = likelihood, I = impact. The full register, with existing controls, residual likelihood and impact, and due dates, is in the companion Excel workbook.

ID	Asset	Threat	Vulnerability	L	I	Score	Treatment	Annex A	Residual	Owner
R02	Supplier payments	Invoice or bank-detail change fraud (business email compromise)	No call-back check; single approver	4	5	20	Call-back on a known number for any bank-detail change; second approval over N500,000	A.5.14, A.5.19, A.6.3	5	Finance Manager
R01	WhatsApp Business account	Account takeover via verification-code scam	No two-step verification PIN; staff unaware of code scams	4	4	16	Set PIN and recovery email; staff rule: never share codes; check linked devices weekly	A.5.17, A.6.3, A.8.5	8	Sales Manager
R03	Business email	Credential theft through phishing	Shared password; no two-step verification	4	4	16	Individual accounts, two-step verification, phishing training	A.5.15, A.5.17, A.8.5	6	Security Lead
R04	Customer personal data	Personal data breach from emailed spreadsheets	Exports emailed and saved on personal devices	3	4	12	One controlled system; stop emailing exports; data minimisation	A.5.14, A.5.34, A.8.12	6	Data Protection Lead
R05	Regulatory standing (NDPA)	Failure to notify a breach within 72 hours	No incident plan; duty not known	3	4	12	Breach response plan, NDPC notification template, annual drill	A.5.24, A.5.26, A.5.34	4	Data Protection Lead
R06	Laptops and phones	Loss or theft exposing data	No disk encryption; no remote wipe	3	3	9	Encrypt laptops, enable find-and-wipe, device register	A.8.1, A.8.24, A.7.9	4	IT Support
R08	All systems	Former staff retaining access	No leaver process	3	3	9	Leaver checklist actioned the same day; quarterly access review	A.5.18, A.5.15	3	HR Manager
R09	Laptops	Malware through unpatched software	Updates not automatic; two devices without protection	3	3	9	Automatic updates; endpoint protection on all devices	A.8.7, A.8.8	4	IT Support
R12	Instagram and Facebook pages	Page hijack through fake copyright notices	Single admin; no two-step verification	3	3	9	Two admins, two-step verification, staff briefing	A.5.17, A.6.3, A.8.5	3	Marketing Lead

ID	Asset	Threat	Vulnerability	L	I	Score	Treatment	Annex A	Residual	Owner
R07	Shared files	Ransomware or accidental deletion	No backup of shared drive; restore never tested	2	4	8	Automatic cloud backup with version history; six-monthly restore test	A.8.13, A.8.7	3	IT Support
R10	Payment gateway and cloud accounting vendors	Supplier security failure affecting the business	No security checks or contract terms	2	4	8	Supplier questionnaire; security and data protection clauses at renewal	A.5.19, A.5.20, A.5.23	6	Finance Manager
R14	Key staff	Loss of the only person who knows account passwords	Passwords held by one person	2	4	8	Business password manager with shared vault and recovery	A.5.17, A.5.30	3	Managing Director
R11	Office network	Unauthorised access via Wi-Fi	Default router password; visitors on staff network	2	3	6	Change defaults; separate guest network	A.8.20	2	IT Support
R15	Regulatory standing (data protection registration)	Missing NDPC registration if thresholds are crossed	Data volumes not tracked	2	3	6	Track data-subject numbers; register with the NDPC if required	A.5.31, A.5.34	2	Data Protection Lead
R13	Website	Defacement or form abuse	Outdated plugins; no bot protection on forms	2	2	4	Update plugins; add bot protection; review admin accounts	A.8.8, A.8.9	2	Marketing Lead

5. Treatment decisions

All fifteen risks are **treated** (reduced). None are transferred: cyber insurance was considered for R02 but is not yet cost-effective at this size, and will be reconsidered at the annual review. No risks are accepted above Low without a dated plan, in line with the appetite statement.

6. Review and ownership

The security and data protection lead keeps this register, reports monthly to the Managing Director on every High and Critical risk, and re-scores the register each quarter. A new assessment is triggered by any incident, a new system or supplier, a new site, or a change in law.

Annex A references use the ISO/IEC 27001:2022 numbering, for example A.5.17 Authentication information, A.6.3 Information security awareness, education and training, A.8.5 Secure authentication, A.8.13 Information backup.